

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by architectural elements, including a large archway and a building with a tower. The text "CONIMBRICA" is inscribed in a circular border around the central figure, and "SITATIS" is visible at the bottom left of the seal.

Security Auditing

Lesson#4

ISO 27002 Controls

School Year 2025/2026

Master in Informatics Engineering (MEI)
Master in Informatics Security (MSI)

Informatics Engineering Department

University of Coimbra



Learning Objective

- Understand the controls for ISO 27000
- Discuss risk concept in Information Security



Agenda

1. ISO 27002: Code of Practice for Information Security Controls
2. ISO 27005: Information Security Risk Management



Agenda

1. ISO 27002: Code of Practice for Information Security Controls

1.1 Purpose of ISO 27002

1.2 Structure and Domains of ISO 27002

1.3 Key Security Controls and Best Practices

1.4 Alignment with ISO 27001



1.1 Purpose of ISO 27002

- What is ISO 27002?

- A guidance document that provides a detailed list of security controls to manage information security risks.
- Originally derived from **ISO 27001 Annex A** but with expanded descriptions and implementation guidance.
- Helps organizations choose appropriate security controls based on risk assessments.

- How ISO 27002 Supports ISO 27001:

- ISO 27001 tells you what to do (management framework for ISMS).
- ISO 27002 tells you how to do it (specific security control recommendations).



1.1 Purpose of ISO 27002

- Who Uses ISO 27002?
 - Organizations implementing ISO 27001 and requiring detailed security measures.
 - Companies not seeking ISO 27001 certification but needing best practices for securing information.
- Can you mention any ISO 27001 detailed security measures?

1.2 Structure and Domains of ISO 27002

ISO 27002 is structured into four major security domains, covering 93 controls in the latest 2022 revision:

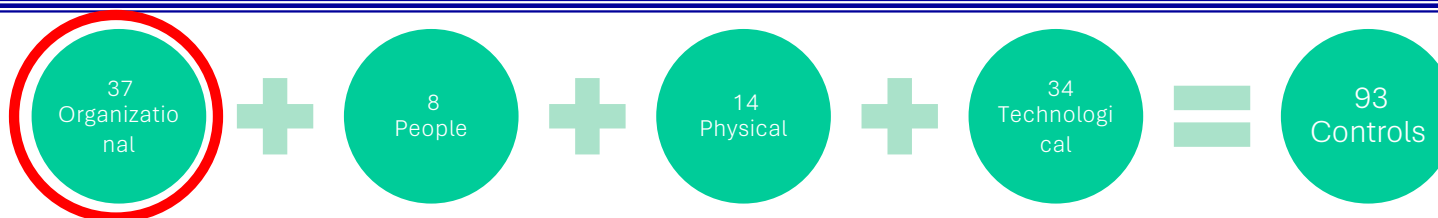




1.2 Structure and Domains of ISO 27002

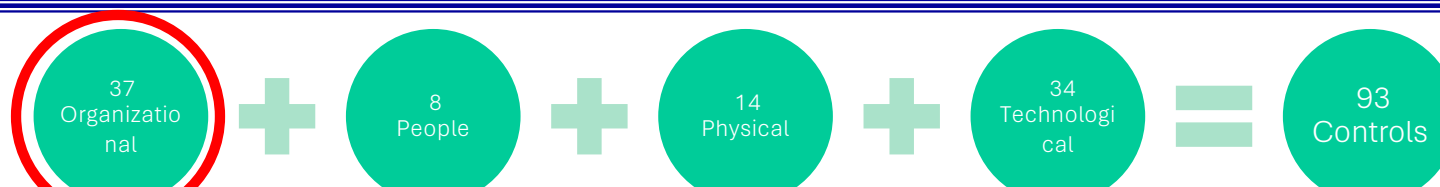
- Key Update in 2022 Version:
 - The previous 14 control categories were consolidated into 4 domains for a simplified and risk-based approach.
 - Introduction of 5 new security attributes to classify controls:
 - Preventive, Detective, Corrective, Governance, Assurance.
- Question:
 - Which security domain (Organizational, People, Physical, or Technological) is most relevant to your role? And why?

1.3 Key Security Controls and Best Practices



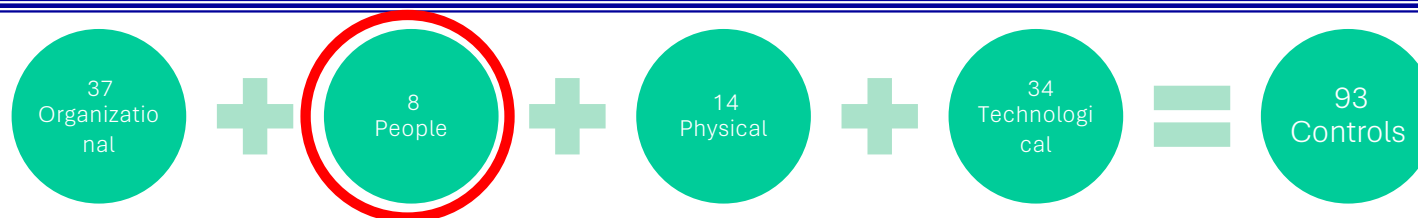
Annex A	Control	Annex A	Control
A 5.1	<u>Policies for information security</u>	A 5.10	Acceptable use of Information and Other Associated Assets
A 5.2	<u>Information Security Roles and Responsibilities</u>	A 5.11	Return of Assets
A 5.3	<u>Segregation of Duties</u>	A 5.12	<u>Classification of Information</u>
A 5.4	Management Responsibilities	A 5.13	Labelling of Information
A 5.5	Contact with Authorities	A 5.14	Information Transfer
A 5.6	Contact with Special Interest Groups	A 5.15	<u>Access Control</u>
A 5.7	<u>Threat Intelligence</u>	A 5.16	<u>Identity Management</u>
A 5.8	Information Security in Project Management	A 5.17	Authentication Information
A 5.9	<u>Inventory of Information and Other Associated Assets</u>	A 5.18	Access Rights

1.3 Key Security Controls and Best Practices



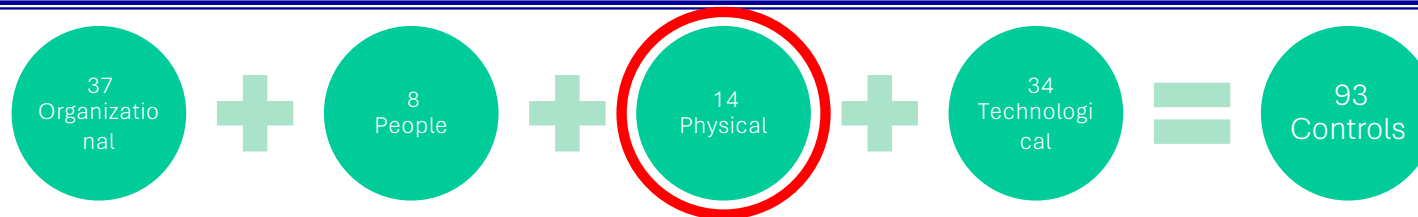
Annex A	Control	Annex A	Control
A 5.19	<u>Information Security in Supplier Relationships</u>	A 5.29	Information Security during Disruption
A 5.20	Addressing Information Security within supplier agreements	A 5.30	ICT readiness for business continuity
A 5.21	<u>Managing Information Security in the ICT Supply Chain</u>	A 5.31	Legal, statutory, regulatory and contractual requirements
A 5.22	Monitoring, review, and Change Management of Supplier Services	A 5.32	Intellectual property rights
A 5.23	Information Security for Use of Cloud Services	A 5.33	Protection of records
A 5.24	<u>Information Security Incident Management Planning and Preparation</u>	A 5.34	Privacy and protection of PII
A 5.25	Assessment and Decision on Information Security Events	A 5.35	Independent review of information security
A 5.26	Response to Information. Security Incidents	A 5.36	<u>Compliance with policies, rules and standards for information security</u>
A 5.27	Learning from information security incidents	A 5.37	Documented operating procedures
A 5.28	Collection of evidence		

1.3 Key Security Controls and Best Practices



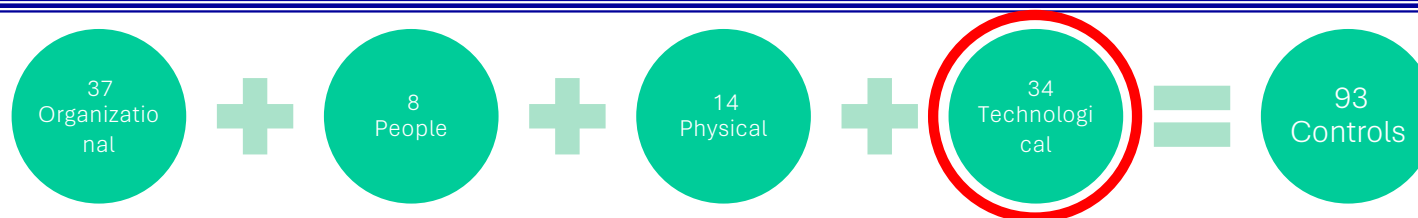
Annex A	Control	Annex A	Control
A 6.1	Screening	A 6.5	Responsibilities after termination or change of employment
A 6.2	Terms and conditions of employment	A 6.6	Confidentiality or non-disclosure agreements
A 6.3	<u>Information security awareness, education and training</u>	A 6.7	<u>Remote working</u>
A 6.4	Disciplinary process	A 6.8	<u>Information security event reporting</u>

1.3 Key Security Controls and Best Practices



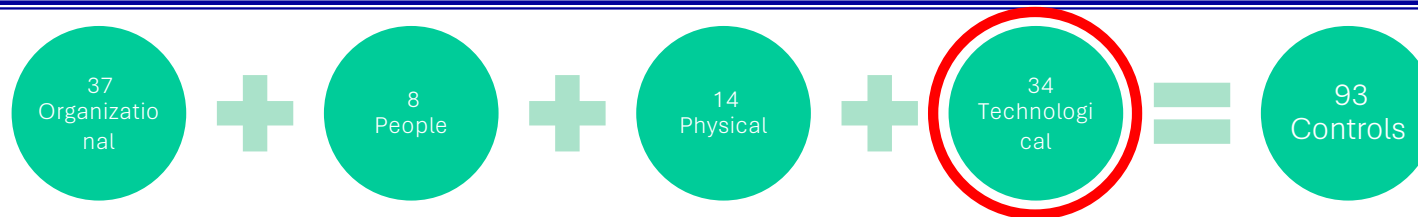
Annex A	Control	Annex A	Control
A 7.1	Physical security perimeters	A 7.8	Equipment siting and protection
A 7.2	<u>Physical entry</u>	A 7.9	<u>Security of assets and protection</u>
A 7.3	Securing offices, rooms and facilities	A 7.10	<u>Storage media</u>
A 7.4	Physical security monitoring	A 7.11	Supporting utilities
A 7.5	Protecting against physical and environmental threats	A 7.12	Cabling security
A 7.6	Working in secure areas	A 7.13	Equipment maintenance
A 7.7	<u>Clear desk and clear screen</u>	A 7.14	<u>Secure disposal or re-use of equipment</u>

1.3 Key Security Controls and Best Practices



Annex A	Control	Annex A	Control
A 8.1	<u>User endpoint devices</u>	A 8.10	Information deletion
A 8.2	<u>Privileged access rights</u>	A 8.11	Data masking
A 8.3	Information access restriction	A 8.12	Data leakage prevention
A 8.4	Access to source code	A 8.13	<u>Information backup</u>
A 8.5	<u>Secure authentication</u>	A 8.14	Redundancy of information processing systems
A 8.6	Capacity management	A 8.15	Logging
A 8.7	Protection against malware	A 8.16	Monitoring activities
A 8.8	Management of technical vulnerabilities	A 8.17	Clock synchronization
A 8.9	<u>Configuration management</u>		

1.3 Key Security Controls and Best Practices



Annex A	Control	Annex A	Control
A 8.18	Use of privileged utility programs	A 8.27	Secure system architecture and engineering principles
A 8.19	Installation of software on operational systems	A 8.28	Secure coding
A 8.20	<u>Networks security</u>	A 8.29	Security testing in development and acceptance
A 8.21	Security of network services	A 8.30	Outsourced development
A 8.22	Segregation of networks	A 8.31	Separation of development, test and production environments
A 8.23	Web filtering	A 8.32	Change management
A 8.24	Use of cryptography	A 8.33	Test information
A 8.25	<u>Secure development lifecycle</u>	A 8.34	Protection of information systems during audit testing
A 8.26	Application security requirements		



1.4 ISO 27002 Alignment with ISO 27001

- ISO 27002 Expands on ISO 27001 Annex A:
 - ISO 27001 Annex A lists security control objectives.
 - ISO 27002 provides detailed implementation guidelines for these controls.
- How They Work Together:
 - ISO 27001 requires a risk assessment.
 - Based on risk levels, the organization selects appropriate controls from ISO 27002.
 - The selected controls are documented in the Statement of Applicability (SoA).
 - ISO 27002 provides best practices for implementation for those controls.



1.4 ISO 27002 Alignment with ISO 27001

- Example: Access Control Alignment

- ISO 27001 Annex A: "Access to information should be controlled."
- ISO 27002: "Use multi-factor authentication, role-based access control, and least privilege policies."

- Using ISO 27002 Without ISO 27001 Certification:

- Organizations can implement ISO 27002 controls even if they don't plan to get ISO 27001 certification.
- Useful for companies seeking **best practices for cybersecurity** without full compliance certification.



Agenda

2. ISO 27005: Information Security Risk Management

2.1 Risk Management Framework in ISO 27005

2.2 Identifying and Analyzing Risks

2.3 Risk Evaluation and Treatment Options

2.4 Integration with ISO 27001 ISMS



2.1 Risk Management Framework in ISO 27005

- What is ISO 27005?

- ISO 27005 provides a **structured approach** for managing information security risks. It aligns with ISO 27001 Clause 6.1 (Actions to address risks and opportunities) and Annex A (Risk-based controls).

- Key Objectives of ISO 27005:

- Helps organizations identify, assess, and treat information security risks.
- Supports ISO 27001's risk-based approach.
- Ensures that risk management is systematic and repeatable.
- Helps organizations prioritize security investments.



2.1 Risk Management Framework in ISO 27005

- Risk Management Process Flow in ISO 27005:
 - **Context Establishment:** Define scope, boundaries, and risk criteria.
 - **Risk Identification:** Recognize threats, vulnerabilities, and assets.
 - **Risk Analysis:** Assess likelihood and impact.
 - **Risk Evaluation:** Prioritize risks based on severity.
 - **Risk Treatment:** Apply mitigation, avoidance, transfer, or acceptance.
 - **Risk Monitoring & Review:** Continuously track risks and improvements.
 - **Risk Communication:** Ensure all stakeholders are informed.



2.2 Identifying and Analyzing Risks

- Identifying Information Security Risks

- **What** is at risk? (Assets: Data, systems, people, processes)
- What are the **threats**? (Cyberattacks, data breaches, insider threats)
- What are the **vulnerabilities**? (Weak passwords, outdated software)
- Who are the threat **actors**? (Hackers, competitors, insiders, nation-states)

- Conducting a Risk Analysis

Risk analysis involves determining:

- **Likelihood** (How likely is the risk to occur?)
- **Impact** (How severe would the consequences be?)

2.2 Identifying and Analyzing Risks

• Risk Assessment Methods:

- Qualitative Risk Assessment (Low, Medium, High)
- Quantitative Risk Assessment (Financial impact, probability percentages)
- Hybrid Approach (Mix of qualitative and quantitative)

◆ Example: A cloud service provider might analyze the risk of a DDoS attack by estimating downtime costs and impact on customers.

	Severity/ Consequence (S)				
	Negligible 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
Likelihood (L)	5 Almost certain	Moderate 5	High 10	Extreme 15	Extreme 20
	4 Likely	Moderate 4	High 8	High 12	Extreme 16
	3 Possible	Low 3	Moderate 6	High 9	High 12
	2 Unlikely	Low 2	Moderate 4	Moderate 6	High 8
	1 Rare	Low 1	Low 2	Low 3	Moderate 4

Image credits: <https://www.rya.org.uk/water-safety/guide-risk-assessment>



2.3 Risk Evaluation and Treatment Options

- Risk Evaluation

- Compare risk levels against the organization's **risk appetite**.
- Decide whether to **accept, mitigate, transfer**, or **avoid** the risk.
- **Prioritize** risks based on severity and business impact.

*Risk appetite can be defined as 'the amount and type of risk that an organisation is **willing to take** in order to meet their strategic objectives'. Organisations will **have different risk appetites** depending on their sector, culture and objectives. A range of appetites exist for different risks and these may **change over time**.*

Institute of Risk Management: <https://www.theirm.org/what-we-say/thought-leadership/risk-appetite-and-tolerance/>



2.3 Risk Evaluation and Treatment Options

- Risk Treatment Options

- Risk **Mitigation** (Reduce the Risk)

- Implement security controls to reduce **likelihood** or **impact**.
 - Example: Deploying firewalls and intrusion detection systems to protect a company's network.

- Risk **Avoidance** (Eliminate the Risk)

- Change processes or remove risk exposure.
 - Example: Disabling USB ports on company computers to prevent malware infections.



2.3 Risk Evaluation and Treatment Options

- Risk Treatment Options

- Risk **Transfer** (Shift the Risk to a Third Party)

- Use **insurance** or outsource security operations.
 - Example: Cyber insurance policies covering financial losses from a data breach.

- Risk **Acceptance** (Tolerate the Risk)

- If mitigation is too costly, an organization may **accept** low-risk events.
 - Example: A company accepting the minor risk of occasional password resets instead of implementing expensive biometric authentication.



2.3 Risk Evaluation and Treatment Options

- Creating a Risk Treatment Plan (RTP)

- Document security controls chosen for each risk.
- Map controls to ISO 27001 Annex A and ISO 27002.
- Define timelines, responsible persons, and budgets.

◆ Example: A financial services firm implements network segmentation and data encryption to mitigate the risk of insider threats.



2.4 Integration with ISO 27001 ISMS

How ISO 27005 Aligns with ISO 27001

ISO 27001 Clause	ISO 27005 Integration
Clause 4: Context of the Organization	Define scope and risk criteria.
Clause 6: Risk Management	Conduct risk assessment and treatment.
Annex A: Security Controls	Implement mitigations based on ISO 27005 findings.
Clause 9: Performance Evaluation	Continuously monitor and review risks.



2.4 Integration with ISO 27001 ISMS

- How Risk Management Enhances ISMS
 - Ensures an adaptive security strategy based on evolving threats.
 - Helps organizations allocate resources effectively.
 - Improves compliance with GDPR, HIPAA, PCI-DSS, and other regulations.



Live Exercise on Risk Assessment

This risk assessment exercise will help students apply ISO 27005 principles to a real-world scenario.

The goal is to identify risks, assess their impact and likelihood, and determine treatment options using a risk matrix.

• Exercise Overview

- **Scenario:** Your company, **SecureBank**, is a mid-sized financial institution that recently expanded its online banking services. You have been tasked with identifying and assessing **security risks related to online transactions and customer data protection**.

• Objectives:

1. Identify potential **threats and vulnerabilities** in the system.
2. Analyze **risk impact and likelihood**.
3. Recommend a **risk treatment strategy**.



Live Exercise on Risk Assessment

- **Step 1: Identifying Threats and Vulnerabilities**

- What possible threats?
- What actors?

Threat	Brief Description



Live Exercise on Risk Assessment

- **Step 2: Assessing Risk Likelihood and Impact**

– Assess risk using this table:

Risk Level	Likelihood (L)	Impact (I)	Risk Score (L x I)
Low (1– 3)	Rare / Unlikely	Minimal Impact	1 - 3
Medium (4 – 6)	Possible	Moderate Impact	4 - 6
High (7 – 9)	Likely / Almost Certain	Significant Impact	7 - 9



Live Exercise on Risk Assessment

- **Step 2: Assessing Risk Likelihood and Impact**

– Assess risk using this table:

Threat	Likelihood (L)	Impact (I)	Risk Score (L x I)	Risk Level



Live Exercise on Risk Assessment

- **Step 3: Choosing Risk Treatment Strategies**

– Assess risk using this table:

Threat	Risk Level	Treatment strategy	Recommended Control



Summary

- ISO 27002 provides detailed guidance on security controls that complement ISO 27001.
- Organizations can customize these controls based on their risk assessment and compliance needs.
- ISO 27005 provides a structured approach to managing security risks.
- A risk matrix helps prioritize threats and allocate resources effectively.
- Risk treatment decisions should balance security, cost, and business impact.
- Regular risk assessments are necessary to adapt to evolving cyber threats.